

보안 점검 및 감사 지침



주식회사 모인

목차

제1장	총 칙	4
제1조	【 목적 】	4
제2조	【 적용 범위 】	4
제3조	【 용어 정의 】	4
제4조	【 책임사항 】	4
제2장	보안감사 일반사항	5
제5조	【 보안감사의 구분 】	5
제6조	【 보안감사의 범위 】	5
제7조	【 보안감사 조직 및 인력구성 】	6
제8조	【 보안감사인의 의무 】	6
제9조	【 보안감사인의 권한 】	6
제3장	보안감사의 수행	7
제10조	【 보안감사 계획 】	7
제11조	【 보안감사 수행 】	7
제12조	【 보안감사 방법 】	8
제13조	【 보안감사 증거의 수집 】	8
제14조	【 보안감사 증거의 요건 】	8
제15조	【 보안감사의 기록 】	8
제4장	보안감사 결과 처리	9
제16조	【 보안감사 결과의 보고 】	9
제17조	【 보안감사 결과 보고서 작성 】	9
제18조	【 보안감사 결과의 이행조치 】	10
부칙		10
제1조	【 시행일 】	10
제2조	【 예외적용 】	10
제3조	【 경과조치 】	10
관련 서식		10

제1장 총 칙

제1조 【 목적 】

본 지침은 주식회사 모인(이하 “회사”라 한다)의 정보통신설비에 대한 주기적인 보안 점검을 수행함으로써 주요 자산의 위협에 대한 노출을 최소화하는데 그 목적이 있다.

제2조 【 적용 범위 】

본 지침은 회사의 모든 정보통신설비를 대상으로 한다.

제3조 【 용어 정의 】

- ① 취약점 : 정보통신설비 내에서 일반사용자가 권한 상승하여 관리자 권한을 획득하거나 비인가 외부자가 특정 권한을 획득할 수 있는 보안상의 결함을 말한다.
- ② 포트 : 일반적으로 포트는 다른 장치에 물리적으로 접속되는 특정한 부위를 말하나, 네트워크에서는 인터넷이나 기타 다른 네트워크 메시지를 서버에 전달 혹은 도착하는 출입구를 말한다.

제4조 【 책임사항 】

- ① 정보보안담당자
 - 1. 정보통신설비에 대하여 주기적(년1회 이상)으로 취약점 점검이 이루어지도록 관리·감독을 수행한다.
 - 2. 점검결과를 정보보안관리자에게 보고하고 발견된 취약점은 해당 설비 관리자가 제거하도록 조치한다.
 - 3. 취약점 점검업무를 자체적으로 수행하기 어려운 경우 관련기관이나 외부 정보보안 업체를 통해 지원받도록 한다.
- ② 정보통신설비 담당자 : 서버, 네트워크 장비, 정보보안시스템 등 정보통신설비에 대하여 해당 설비 담당자는 발견된 취약점을 제거할 의무를 갖는다.
- ③ 정보보안 감사인
 - 1. 보안 감사인은 정보보안담당자 및 관리자, 감사부서 직원으로 감사 책임자가 지정한 자가 수행한다.

[보안 점검 및 감사 지침]

2. 보안 감사인은 보안감사 범위와 요구사항 정의, 피감사부서와 협의, 보안감사 계획 수립 및 주관 등 보안감사의 실행에 대한 책임을 갖는다.
3. 보안 감사인은 전문적인 기술이 필요한 경우 내·외부 전문 인력을 포함 할 수 있다.

제2장 보안감사 일반사항

제5조 【 보안감사의 구분 】

- ① 보안감사는 정기적으로 수행하는 정기 보안감사와 비정기적으로 수행하는 수시 보안 감사, 특별 보안감사로 구분하여 실시할 수 있다.
- ② 정기 보안감사는 연간 보안감사 계획에 따라 실시하는 계획된 감사를 말하며 기본적으로 년 1회 이상 실시한다.
- ③ 특별 보안감사는 정보보안 사고의 징후가 있어 확인이 필요한 경우 또는 정보보안 사고 발생시 실시한다.
- ④ 수시 보안감사는 정보보안 관련 활동 및 업무 중요도를 고려하여 수시로 해당 업무의 일부 또는 전반에 대하여 보안감사가 필요하다고 인정되는 경우 정기감사와는 별도로 실시 할 수 있다.

제6조 【 보안감사의 범위 】

- ① 보안감사는 정보보안관리체계에 기반한 정보보안 정책 및 지침에 근거한 모든 정보보안 활동을 대상 범위로 한다.
- ② 보안감사의 대상은 정보시스템, 응용시스템, 데이터베이스 및 이에 대한 관리인력, 이를 이용하는 임직원 및 외부인을 대상으로 한다.
- ③ 보안감사의 범위는 다음의 사항을 포함한다.
 1. 회사의 정보보안 정책, 지침, 절차 등의 준수 여부 확인
 2. 회사의 정보보안 정책, 지침, 절차 준수에 따른 기록의 적정성 확인
 3. 정보보안 관리체계(ISMS)의 통제요건 준수 여부
 4. 정보보안 관련 법률에 따른 준수 사항 확인
 5. 기타 이에 준하는 것으로서 필요한 사항 및 전기 보안감사 부적합 사항에 대한 시정 여부 확인

제7조 【보안감사 조직 및 인력구성】

- ① 보안감사 조직 구성은 보안감사의 총괄적인 활동을 감독하는 감사 책임자를 선정하고 정보보안담당자 및 관리자, 감사부서 직원 중 감사 책임자가 지정한 감사인으로 한다.
- ② 보안감사는 감사부서에서 수행하며 정보보안에 관한 지원이 필요한 경우 정보보안팀 또는 외부 보안 전문가를 포함할 수 있다.

제8조 【보안감사인의 의무】

- ① 보안감사인은 보안감사와 관련되는 모든 사항에 대하여 항상 독립성과 공정한 태도를 견지하여야 한다.
- ② 보안감사인은 보안감사와 관련하여 취득한 사실을 정당한 사유없이 외부 또는 타인에게 누설해서는 아니 된다.
- ③ 보안감사인은 감사를 실시함에 있어 피감사부서로 하여금 업무상 창의와 활동이 위축되거나 침체되지 않도록 상당한 주의를 하여야 한다.
- ④ 보안감사인은 사전에 보안감사계획을 작성하고 그에 따라 질서정연하게 보안감사를 실시하여야 한다.

제9조 【보안감사인의 권한】

- ① 보안감사인은 공정한 보안 감사업무 수행을 위하여 타인의 간섭을 받지 않는 독립성을 가진다.
- ② 보안감사인은 규정위반 또는 그 직무를 성실히 수행하지 아니한 경우를 제외하고는 신분상의 불리한 처분을 받지 아니한다.

제3장 보안감사의 수행

제10조 【보안감사 계획】

- ① 보안감사 조직은 보안감사를 실시하기 위해 연간 보안감사계획을 수립하고 이에 따라 보안감사를 실시한다.

[보안 점검 및 감사 지침]

② 보안감사 계획에는 다음의 내용이 포함되어야 한다.

1. 보안감사의 목적 및 종류
2. 보안감사 대상 및 범위
3. 보안감사 항목
4. 보안감사 시기 및 일정
5. 보안감사 실시의 업무분담과 담당자
6. 보안감사보고서 제출 예정일

③ 특별 보안감사는 정보보안 사고 징후, 정보보안 사고 발생 시 계획을 수립하여 실시하며 보안감사 대상, 방법 등을 포함하여야 한다.

제11조 【보안감사 수행】

① 보안감사인원은 보안감사 계획에 따라 보안감사를 수행하여야 한다.

② 보안감사인원은 업무 중단의 위험을 최소화할 수 있도록 업무 환경을 고려하여 보안 감사를 수행하여야 한다.

③ 보안감사인원은 보안감사 결과를 관리하고 보안감사에서 지적된 사항에 대한 조치 여부를 감독하여야 한다.

④ 보안감사인원은 정기 보안감사 및 수시 보안감사 실시 이전 감사기일 및 범위를 피감사부서의 장에게 사전 통고하여야 한다. 단, 특별 보안감사 실시하는 경우 사전 통고를 생략할 수 있다.

⑤ 피감사부서의 장은 보안감사 실시시 보안감사인의 요구가 있을 때에는 지체없이 자료제출 또는 답변을 하여 보안감사의 원활한 수행에 협조하여야 한다.

제12조 【보안감사 방법】

① 보안감사인은 보안감사 계획에 따라 보안감사를 수행한다.

② 취약점 점검은 보안감사를 실시하기 전에 상용/공개 취약점 점검도구로 진단 및 수작업으로 점검하거나 외부 정보보안업체 등을 통하여 수행할 수 있다.

③ 회사에서 사용하고 있는 취약점 점검도구, 점검 **script**, 보안 설정 체크리스트를 사용 하거나, 또는 취약점 점검도구를 새로 도입할 수 있다.

④ 취약점 점검도구 관리

1. 취약점 점검도구의 사용 및 관리는 정보보안담당자로 제한한다.

[보안 점검 및 감사 지침]

2. 정보보안담당자는 취약점 점검도구의 접근통제에 대한 관리책임을 가지며, 새로운 취약점이 발견될 경우 취약점 점검도구의 룰 업데이트를 실시한다.

제13조 【 보안감사 증거의 수집 】

- ① 보안감사인인 피감사부서에 적용되는 정보보안 정책 및 지침의 항목에 대해 이행되고 있음을 확인하기 위한 감사증거를 수집하여야 한다.
- ② 보안감사인인 보안감사를 실시하기 전에 보안감사 관련 자료를 피감사부서에 요청할 수 있으며 피감사부서는 이에 대한 자료를 보안감사 시작 전까지 제출하여야 한다.
- ③ 보안감사인인 보안감사 항목에 대해 담당자 인터뷰, 시스템 설정 및 운영 결과 검토, 취약점 진단 및 분석 등을 통해 필요한 감사증적(Audit Trail)을 확보한다.

제14조 【 보안감사 증거의 요건 】

- ① 보안감사 시 보안감사의 대상에 대해서만 감사증거를 수집하여야 한다.
- ② 보안감사 대상영역에 대한 보안감사 증거(Audit Trail)를 확보하고 증거자료의 무결성이 보장되도록 관리하여야 한다.

제15조 【 보안감사의 기록 】

- ① 보안감사 결과 수집된 보안감사 증거를 문서화하여 관리하여야 한다.
- ② 보안감사 기록은 비공개를 원칙으로 한다.

제4장 보안감사 결과 처리

제16조 【 보안감사 결과의 보고 】

- ① 보안감사인인 보안감사 실시 후 감사 책임자에게 보안감사 결과를 제출한다.
- ② 감사 책임자는 보안감사 결과 검토 후 대표이사에게 직접 보고하여야 한다.
- ③ 감사 책임자가 정보보호위원회에 보안감사의 요약 내용 및 주요 보안감사 결과를 보고 한다.
- ④ 보안감사인인 보안감사 수행 중 중대한 정보보안 사고를 발견한 경우 지체없이 감사 책임자에게 보고하여야 한다.

[보안 점검 및 감사 지침]

- ⑤ 보안감사인은 보안감사보고서가 임의로 유출되지 않도록 주의하여야 하며 피감사부서의 장에게 보안감사결과를 주의하여 전달한다.

제17조 【 보안감사 결과 보고서 작성 】

- ① 보안감사보고서는 다음 사항을 명시하고 주요 결과를 요약하여 기술한다.
1. 보안감사 기간
 2. 피감사부서명 및 보안감사인의 직위 및 성명
 3. 보안감사의 목적 및 구분
 4. 보안감사의 범위
 5. 보안감사 개요
 6. 주요 감사내용
 7. 보안감사 결과에 대한 문제점 또는 지적 사항
 8. 보안감사결과 종합의견
 9. 시정사항 및 건의사항
 10. 기타 보고의 필요성이 있는 사항
- ② 취약점 점검을 통해 발견된 취약점에 대해서 적절한 조치와 이행조치 계획을 수립 하여야 한다.
보안감사 후 감사 지적 사항에 대해서는 피감사부서장의 의견이나 향후 조치계획 등이 함께 기술될 수 있다.
- ③ 보안감사의 일부를 외부 전문가를 활용하여 시행한 경우 외부 전문가에 의해 시행된 범위를 명시한다.

제18조 【 보안감사 결과의 이행조치 】

- ① 감사 책임자는 시정이 필요한 피감사부서의 장에게 시정조치를 요구할 수 있다.
- ② 피감사부서장은 중·장기적으로 해결되어야 할 개선사항에 대하여 이행계획을 수립하여 제출 한 후 조치를 수행하며, 보안감사인은 해당 내용을 차기 정기 감사의 대상으로 기록·관리하여야 한다.

부칙

제1조 【 시행일 】

본 지침은 대표이사가 승인한 날부터 시행한다.

제2조 【 예외적용 】

다음 각 항에 해당하는 경우에는 본 규정에서 명시한 내용일지라도 정보보호최고책임자(CISO)의 승인을 받아 예외 취급할 수 있다.

- ① 기술환경의 변화로 적용이 불가능할 경우
- ② 기술적, 관리적 필요에 따라 지침의 적용을 보류할 긴급한 사유가 있을 경우
- ③ 기타 재해 등 불가항력적인 상황일 경우

제3조 【 경과조치 】

특별한 사유에 의하여 본 규정에 정하는 요건을 충족하지 못한 경우에는 시행일로부터 1년 이내에 개선방안을 강구하여야 한다.

관련 서식

[첨부1] 정보보안 감사 조직

[첨부2] 시정조치 요구서

[첨부3] 취약점 점검 내역서

[보안 점검 및 감사 지침]

[첨부1] 정보보안 감사 조직

역 할	소속 / 직위	성 명
감사 책임자		
감사인		
감사인		
감사인		
감사인		

[보안 점검 및 감사 지침]

[첨부2] 시정조치 요구서

CORRECTIVE ACTION Request		발행일	
시정조치요구서		CAR No:	
피감사	부서명		
부서	담당자		
감사인	성 명		
	부서/소속		
AUDIT REF(Clause)			
지적 사항 구분 (해당되는 영역에 표시하여 주세요.)			
정보보안관리과정		문서화	
정보보안대책요구사항		정책/지침	
부적합 사항			

[보안 점검 및 감사 지침]

[첨부3] 취약점 점검 내역서

취약점 점검 내역서

정보보안 담당자	정보보안 관리자	정보보안 책임자

구분		IP 주소 범위	장비위치	설치된 응용프로그램
점검대상	서버			
	네트워크			
	PC			
	정보보안시스템			
	기타			
주요점검항목				
점검자/연락처		시스템개발팀 정보보안담당자 홍길동 / 010-000-0000		
점검기간		~		
주요점검결과			조치사항	
건의사항				

[보안 점검 및 감사 지침]

